



ARKA HEALTH, INC.

HITRUST E1 READINESS ROADMAP

Path to HITRUST Essentials, 1-Year (e1) Validated Assessment under HITRUST CSF v11

ARKA-RDY-003 · Version 1.0 · Confidential — Internal

Document No.	ARKA-RDY-003
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. RATIONALE FOR THE e1 TIER

Hospital systems and payers increasingly request HITRUST assurance from clinical software vendors. HITRUST offers three progressive assessments — e1 (44 curated requirements addressing essential cybersecurity hygiene), i1 (leading-practice, ~180 requirements), and r2 (expanded, risk-based). For a company of ARKA’s size and data posture, the **e1 Validated Assessment** is the appropriate entry tier: it is achievable on a startup budget and timeline, produces a certification (unlike the readiness self-assessment), is renewed annually, and shares an estimated 80–90% control overlap with the SOC 2 program documented in ARKA-RDY-002, allowing one body of evidence to serve both. ARKA will pursue e1 certification following issuance of the SOC 2 Type I report, with progression to i1 evaluated at the first e1 renewal. **ARKA is not HITRUST certified and makes no such representation until a validated assessment is issued.**

2. CONTROL-DOMAIN COVERAGE

The e1’s 44 requirement statements concentrate on foundational practices. ARKA’s mapping, using the same status conventions as ARKA-RDY-002:

e1 focus area	ARKA implementing policy / control	Status
Access control & MFA	SEC-003 (RBAC matrix, FIDO2 for administrators, session limits)	Partial
Endpoint protection	SEC-012 (managed endpoints, FDE, EDR)	Implemented
Patch & vulnerability management	SEC-010, § 5 (CI dependency audit; 6-month scans; annual pen test)	Partial
Logging & monitoring	SEC-005 (centralized, immutable logs; alert catalog)	Partial
Incident response	SEC-006 (plan, severity model, annual exercise)	Implemented
Backup & resilience	SEC-007 (immutable offsite backups, tested restores)	Partial
Configuration hardening	SEC-001, § 5(g) (CIS benchmarks; IaC)	Partial
Network protection & segmentation	SEC-001, § 5(f); provider-managed isolation	Implemented
Data protection & encryption	SEC-004 (AES-256; TLS 1.2+; KMS custody)	Implemented
Third-party risk	SEC-009 (tiering, BAAs, annual verification)	Implemented
Security awareness	SEC-008 (onboarding + annual training, attestations)	Implemented
Spam/phishing protection	Corporate mail filtering; phishing-resistant MFA	Implemented

3. EXECUTION PLAN

- Phase 1 — Foundation (now – Q4 2026).** Close R-1 through R-5 (RDY-001, § 5); accrue ninety (90) days of operating evidence; complete SOC 2 Type I.
- Phase 2 — Self-assessment (Q1 2027).** License MyCSF; complete the e1 readiness assessment in-platform; remediate scoring shortfalls below required maturity (PRISMA “implemented” level across all 44 statements).

3. **Phase 3 — Validated assessment (H1 2027).** Engage an authorized HITRUST External Assessor; complete validated testing; submit through MyCSF for HITRUST quality assurance and certification issuance.
4. **Phase 4 — Maintenance (annually).** Renew e1 each year; evaluate progression to i1 once headcount and customer requirements justify the expanded control set.

4. BUDGETARY PLANNING (NON-BINDING)

Management plans against industry-reported ranges for a small-scope e1: MyCSF subscription and assessment fees plus external-assessor fees, commonly totaling on the order of the low-to-mid five figures for a company of ARKA's footprint, with internal effort substantially reduced by reuse of SOC 2 evidence. Figures are planning estimates, not quotations, and shall be refreshed upon assessor selection.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026